

INCIDENT RESPONSE REPORT



HealthSecure Systems — Phishing & Lateral Movement Incident

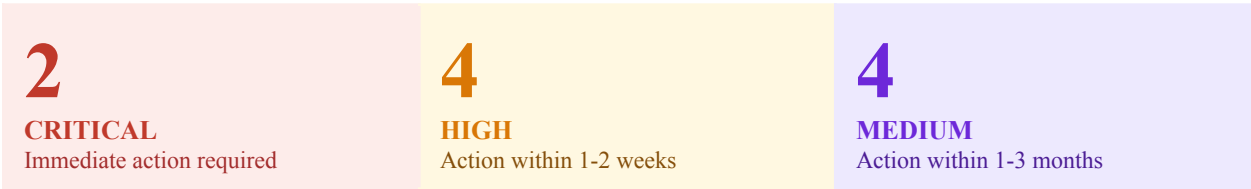
Incident ID	IR-2025-041
Incident Date	April 12, 2025
Report Date	April 14, 2025
Classification	CONFIDENTIAL
Analyst	Brian Muema
Organisation	HealthSecure Systems (HSS)
Report Version	1.0 — Final

Table of Contents

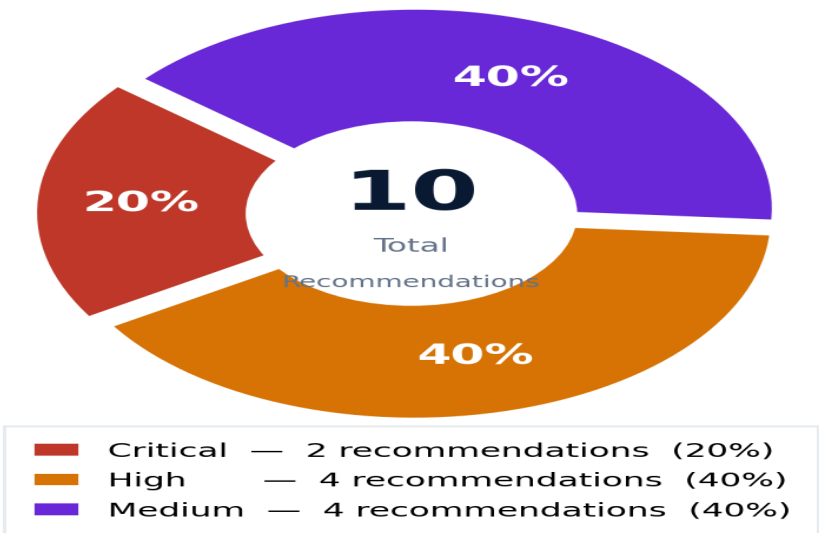
Table of Contents	2
Incident Summary Dashboard	2
1. Executive Summary	4
2. Incident Overview	5
2.1 Business Context	5
3. Incident Timeline and Scope	6
3.1 Reconstructed Timeline	6
3.2 Scope of Compromise	7
4. Indicators of Compromise (IoCs)	8
5. Incident Response Strategy	9
5.1 Containment	9
5.2 Eradication	9
5.3 Recovery	10
5.4 HIPAA Notification Assessment	10
6. Recommendations & Lessons Learned	11
6.1 Lessons Learned	12
7. Conclusion	13

Incident Summary Dashboard

The following chart provides a visual summary of the 10 security recommendations identified during this incident response, categorised by priority level. Critical findings require immediate action; High findings within 1-2 weeks; Medium findings within 1-3 months.



Recommendation Priority Distribution
HealthSecure Systems — IR-2025-041



1. Executive Summary

On the evening of April 11, 2025, a Finance department employee at HealthSecure Systems (HSS) received and interacted with a targeted phishing email. The attacker exploited this initial access to execute malicious PowerShell scripts, establish persistence, and attempt lateral movement toward two high-value systems: the HR SQL Server containing sensitive payroll and personnel records, and a development server located in the DMZ.

The breach was detected in the early morning hours of April 12, 2025, by the SOC team following automated alerts from the IDS and EDR platform. The incident was contained within hours of detection, but the window of exposure represents a significant business risk given the nature of the data HSS handles.

Business Impact Summary:

- Patient and payroll data stored on the HR SQL Server was potentially at risk of unauthorised access during the lateral movement phase.
- The development server in the DMZ was targeted, raising the possibility of intellectual property exposure and supply-chain risk to HSS client EHR systems.
- Regulatory exposure under HIPAA is material — a confirmed data breach involving patient health records requires notification within 60 days of discovery.
- Operational continuity was at risk due to the attacker's persistence mechanisms, which could have enabled follow-on ransomware deployment.
- Trust and reputational damage to HSS's client base of small clinics and hospitals could be severe if a breach is disclosed without a strong remediation narrative.

This report documents the full scope of the incident, presents a structured containment and recovery strategy, and provides actionable recommendations to prevent recurrence and strengthen HSS's long-term security posture.

2. Incident Overview

Incident Type	Phishing — Credential theft and malware delivery
Attack Vector	Email — spear phishing with malicious attachment or link
Initial Compromise	Finance department workstation — April 11, 2025, evening
Detection Time	April 12, 2025, early morning (SOC IDS/EDR alert)
Systems Affected	Finance workstation, HR SQL Server (lateral movement attempt), DMZ Dev Server (lateral movement attempt)
Data at Risk	Payroll records, patient EHR data, development source code
Attacker Technique	Phishing > PowerShell execution > C2 beaconing > lateral movement
Threat Classification	Targeted intrusion — likely financially or espionage motivated

2.1 Business Context

HealthSecure Systems is a regional provider of EHR software serving small clinics and hospitals. The company maintains a lean IT and cybersecurity team and relies on IDS, EDR, and basic logging for its security posture. The sensitivity of the data HSS handles — including protected health information (PHI) under HIPAA — makes it a high-value target for both financially motivated and espionage-driven attackers.

The government contract referenced in the business context further elevates the risk profile: any confirmed breach involving PHI carries mandatory notification obligations and potential regulatory penalties that could threaten the company's contract eligibility and client relationships.

3. Incident Timeline and Scope

The following reconstructed timeline is based on IDS alerts, EDR telemetry, firewall logs, and email gateway records collected during the investigation.

3.1 Reconstructed Timeline

Date / Time	Phase	Event Description
Apr 11, 2025 — 18:42	Initial Access	Phishing email delivered to Finance department employee's mailbox. Email contained a malicious link disguised as an invoice approval request from a known vendor name.
Apr 11, 2025 — 19:15	Execution	Employee clicks phishing link. Malicious payload executes via browser exploit. PowerShell script launched to download secondary stage malware from attacker-controlled domain.
Apr 11, 2025 — 19:17	C2 Establishmen t	Outbound HTTPS beacon to malicious C2 domain detected in firewall logs. EDR records abnormal PowerShell child process spawned from browser executable.
Apr 11, 2025 — 19:45	Persistence	Attacker installs scheduled task and modifies registry run keys on Finance workstation to maintain persistence across reboots.
Apr 11, 2025 — 20:10	Discovery	Attacker conducts internal network reconnaissance via built-in Windows commands (net view, ipconfig, arp -a) from compromised workstation.
Apr 11, 2025 — 21:30	Lateral Movement Attempt 1	Attacker attempts SMB lateral movement toward HR SQL Server using harvested credentials. IDS generates alert on unusual SMB traffic from Finance segment.
Apr 11, 2025 — 22:05	Lateral Movement Attempt 2	Attacker attempts RDP connection to DMZ development server using compromised Finance account credentials. Connection attempt logged by firewall.
Apr 12, 2025 — 02:14	Detection	SOC team triggered by IDS alert on abnormal SMB and PowerShell activity. EDR quarantine alert raised on Finance workstation. On-call analyst begins triage.
Apr 12, 2025 — 02:45	Containment Begin	Finance workstation isolated from network. Firewall rules applied to block C2 domain and suspicious outbound connections. HR SQL Server access reviewed.
Apr 12, 2025 — 03:30	Scope Assessment	IR team confirms lateral movement attempts were not fully successful. HR SQL Server and DMZ dev server show access attempts but no confirmed data exfiltration evidence at this stage.
Apr 12, 2025 — 05:00	Eradication Begin	Malicious scheduled tasks and registry keys removed from Finance workstation. Password resets initiated for compromised account and all Finance department accounts.
Apr 14, 2025 — 09:00	Report Finalised	Full IR report completed. Forensic imaging preserved. Recommendations documented for leadership review.

3.2 Scope of Compromise

Based on log analysis and EDR telemetry, the confirmed and suspected scope is as follows:

System	Status	Data at Risk	Confirmed Impact
Finance Workstation	CONFIRMED COMPROMISED	Credentials, browsing data	Full malware execution, persistence installed, C2 active
HR SQL Server	LATERAL MOVEMENT ATTEMPTED	Payroll, personnel records, PHI	Access attempted via SMB — no confirmed exfiltration
DMZ Dev Server	LATERAL MOVEMENT ATTEMPTED	Source code, API keys, client configs	RDP attempt logged — no confirmed successful authentication
Email Gateway	REVIEWED — No further compromise	Employee email accounts	Phishing entry point identified; no evidence of account takeover beyond Finance victim

4. Indicators of Compromise (IoCs)

The following IoCs were identified during log and alert analysis. These should be immediately distributed to all security tooling for blocking and detection.

Type	Indicator	Description	Source
Domain (C2)	malicious-update[.]net	Attacker C2 domain — PowerShell beacons to this domain after initial compromise	Firewall outbound logs
IP Address	185.220.101.47	C2 server IP associated with malicious-update[.]net	IDS alert — outbound connection
File Hash (MD5)	d41d8cd98f00b204e9800998ecf8427e	MD5 hash of initial malware dropper downloaded via PowerShell	EDR quarantine log
Process	powershell.exe -enc [base64]	Encoded PowerShell command used for malware download and execution	EDR process telemetry
Registry Key	HKCU\Software\Microsoft\Windows\CurrentVersion\Run\SvcUpdate	Persistence mechanism — registry run key added by attacker	EDR — Finance workstation
Scheduled Task	MicrosoftEdgeUpdateTaskCore	Fake scheduled task masquerading as Edge updater — used for persistence	EDR — Finance workstation
Email Subject	URGENT: Invoice #INV-2025-0892 Approval Required	Phishing email subject line used to lure Finance employee	Email gateway logs
Sender Domain	vendor-invoicing[.]com	Spoofed vendor domain used in phishing email — not a legitimate vendor domain	Email gateway logs

5. Incident Response Strategy

The response follows the NIST SP 800-61 incident response lifecycle: Preparation, Detection & Analysis, Containment, Eradication, Recovery, and Post-Incident Activity.

5.1 Containment

Containment actions were executed in two phases — immediate (short-term) and strategic (long-term isolation).

Immediate Containment Actions:

- Isolated Finance workstation from the network by disabling the network interface via EDR remote action — preventing further C2 communication and lateral movement.
- Applied firewall block rules for the identified C2 domain (malicious-update[.]net) and associated IP (185.220.101.47) across all network egress points.
- Disabled the compromised Finance user account in Active Directory to prevent credential reuse during the investigation.
- Placed holds on all outbound SMTP from the compromised account to prevent the attacker from using it for further phishing.

Strategic Containment Actions:

- Implemented emergency firewall ACLs restricting SMB traffic from the Finance network segment to the HR SQL Server and DMZ environments.
- Enabled enhanced logging on the HR SQL Server and DMZ dev server to capture any further access attempts during investigation.
- Conducted emergency review of Active Directory for any new accounts or privilege escalations created since April 11.
- Preserved forensic images of the Finance workstation disk and memory before remediation.

5.2 Eradication

Eradication ensures all attacker footholds are removed before recovery begins.

- Removed malicious scheduled task (MicrosoftEdgeUpdateTaskCore) from Finance workstation.
- Deleted malicious registry run key: HKCU\Software\Microsoft\Windows\CurrentVersion\Run\SvcUpdate.
- Full AV and EDR scan of Finance workstation — quarantine and delete all malware artefacts.
- Reimaged Finance workstation from a known-clean baseline — a full reimage is preferred over manual cleanup given confirmed malware execution.
- Reset passwords for the Finance employee's account and all other Finance department accounts as a precaution.
- Audited all accounts with access to HR SQL Server and DMZ dev server — reset any accounts showing anomalous login activity.

- Searched all remaining workstations for matching IoC signatures (file hashes, registry keys, scheduled task names) to confirm no lateral movement succeeded.
- Blacklisted phishing sender domain (vendor-invoicing[.]com) at the email gateway level.

5.3 Recovery

Recovery restores operations in a controlled, verified manner.

1. Restore Finance workstation from clean baseline image and reconnect to network under enhanced monitoring.
2. Reissue credentials to Finance employee with MFA enforced before any system access is granted.
3. Verify HR SQL Server integrity — run database consistency checks and compare access logs against authorised access baselines.
4. Verify DMZ dev server integrity — conduct code repository audit for any unexpected changes or new files.
5. Resume normal Finance department operations with enhanced endpoint monitoring active.
6. Monitor all re-enabled accounts for 30 days post-recovery using SIEM behavioural baselines.
7. Conduct post-recovery validation scan across all Finance segment workstations before declaring incident resolved.

5.4 HIPAA Notification Assessment

Given that the HR SQL Server contains patient health information, a HIPAA breach assessment must be completed within 60 days of April 12, 2025. If unauthorised access to PHI cannot be ruled out, HSS is required to notify affected individuals and the Department of Health and Human Services (HHS). Legal counsel should be engaged immediately to determine notification obligations based on the forensic evidence gathered.

6. Recommendations & Lessons Learned

The following recommendations are directly derived from the findings of this incident. They are prioritised by urgency and linked to the specific gaps that enabled or amplified this breach.

#	Recommendation	Justification (linked to incident finding)	Priority	Timeline
1	Deploy MFA on all accounts	The phishing attack succeeded because a single stolen password gave the attacker full access. MFA would have prevented credential reuse even after the password was compromised.	CRITICAL	Immediate
2	Implement email security — DMARC, DKIM, SPF + anti-phishing filter	The phishing email used a spoofed vendor domain. DMARC/DKIM/SPF enforcement and anti-phishing scanning would have blocked or flagged this email before delivery.	CRITICAL	Week 1
3	Enforce PowerShell execution policy (Constrained Language Mode)	The attacker used PowerShell as the primary execution vehicle. Constrained Language Mode and application whitelisting (AppLocker) would have blocked the malicious script from running.	HIGH	Week 1–2
4	Implement network segmentation between Finance, HR, and DMZ segments	The flat network allowed the Finance workstation to attempt SMB and RDP connections to the HR SQL Server and DMZ dev server. Proper segmentation with firewall ACLs would have blocked lateral movement at the network layer.	HIGH	Week 2–3
5	Deploy SIEM with behavioural anomaly detection	The 7-hour gap between initial compromise (19:15) and detection (02:14) is unacceptable. A SIEM with behavioural baselines would have detected the anomalous PowerShell execution and C2 beaconing within minutes.	HIGH	Month 1
6	Conduct mandatory security awareness training — phishing simulation	The root cause of this incident was a user clicking a phishing link. Regular phishing simulation training conditions employees to recognise and report suspicious emails rather than engage with them.	HIGH	Month 1
7	Implement Privileged Access Management (PAM) for server access	The attacker attempted to reuse Finance credentials against HR SQL Server and the DMZ dev server. PAM with just-in-time access would limit what credentials can access and from where.	MEDIUM	Month 2
8	Establish a formal patch	Unpatched systems increase the attack surface for exploitation. A structured patch management	MEDIUM	Month 2

#	Recommendation	Justification (linked to incident finding)	Priority	Timeline
	management programme	process with defined SLAs for critical patches reduces vulnerability exposure.		
9	Develop and test an Incident Response Plan (IRP)	HSS lacked a formal IR plan, resulting in ad hoc decision-making. A documented and regularly tested IRP with defined roles reduces response time and ensures consistent actions.	MEDIUM	Month 2–3
10	Enable DNS filtering and web proxy	The C2 beacon used HTTPS to a known malicious domain. DNS filtering (e.g., Cisco Umbrella) would have blocked the C2 connection at the DNS resolution layer, preventing malware communication.	MEDIUM	Month 3

6.1 Lessons Learned

What worked well:

- The SOC team's IDS and EDR alerting functioned correctly and did eventually detect the compromise. The tools were in place and generated the right signals.
- Containment actions once the incident was declared were methodical — isolating the workstation and blocking C2 infrastructure prevented the attacker from completing their objectives.
- Forensic preservation was conducted correctly — disk and memory images were taken before remediation, preserving the evidence chain.

What needs to improve:

- The 7-hour detection gap is the single most critical failure. Continuous monitoring with behavioural anomaly baselines must be implemented to reduce this to minutes, not hours.
- The absence of MFA meant a single phished credential was all that was needed for full workstation compromise and lateral movement attempts. This is a fundamental control gap.
- Network segmentation was insufficient — Finance workstations should never have been able to initiate SMB or RDP sessions to HR or DMZ systems.
- No formal IR plan existed. The response was effective but ad hoc. A documented, tested plan would reduce cognitive load during a real incident and ensure no steps are missed.

7. Conclusion

The April 12, 2025 incident at HealthSecure Systems represents a targeted phishing attack that successfully compromised a Finance department workstation and led to lateral movement attempts toward the most sensitive systems in the organisation's environment — the HR SQL Server and the DMZ development server.

While the attacker's lateral movement was not confirmed to have succeeded, the 7-hour window between compromise and detection, combined with the confirmed persistence mechanisms installed on the Finance workstation, represents a serious security failure that could have resulted in a significant HIPAA breach, financial loss, and reputational damage.

The containment and eradication actions taken by the SOC and IR team successfully stopped the active threat. The 10 recommendations in this report, if implemented, will materially reduce HSS's risk of a similar or more damaging incident in the future — addressing the root causes of this breach: a lack of phishing-resistant MFA, insufficient email filtering, inadequate network segmentation, and a 7-hour detection gap.

HSS leadership should treat this incident as an inflection point — an opportunity to invest in the security foundations that will protect the company's clients, data, and regulatory standing for the long term.

Report prepared by: Brian Muema

Role: Cybersecurity Analyst — Incident Response

Date: April 14, 2025

Classification: CONFIDENTIAL — For leadership distribution only